14 — Procédure de gestion des violations de données

English: ../en/14-data-breach-procedure.md

Cartouche	
Éditeur	Nhill Solution, Kinshasa (République démocratique du Congo)
Version	3.0.0 — 28 octobre 2026
Statut	document interne ; rédigé sans relecture par un avocat ; délai et contenu de la notification à l'autorité à confirmer (V-06, 00 § 5)
Hypothèses	H-03, H-05, H-15, H-19 (00 § 2)
Référence	droit de la RDC (Code du numérique, Livre III) ; le délai de 72 heures du RGPD est retenu comme référence de bonne pratique

1. Définition

Violation de données : toute atteinte à la sécurité entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation ou l'accès non autorisé à des données personnelles (exemples : base exposée, compte d'administrateur compromis, sauvegarde perdue, envoi à un mauvais destinataire, rançongiciel).

2. Rôles

Les rôles sont tenus par des personnes désignées par la direction de Nhill Solution ; la liste nominative à jour (titulaire et suppléant de chaque rôle) est conservée avec le registre des incidents.

Rôle	Mission
Responsable de l'incident	décide, coordonne, tient le registre ; par défaut, la direction
Technique	contient l'incident sur le serveur et la base, conserve les traces
Communication	informe les établissements et les personnes concernées
Conseil juridique	qualifie la violation et la notification à l'autorité

3. Étapes et délais

Délai (à partir de la détection)	Action
immédiat	consigner l'heure de détection dans le registre des incidents ; prévenir le responsable de l'incident
moins de 4 heures	contenir : couper l'accès compromis, révoquer les sessions (par établissement ou globalement), changer les secrets concernés (`NH_SECRET_KEY` seulement si nécessaire : voir ses conséquences dans le guide de configuration), conserver les journaux (`journalctl -u nhill-server`, journal d'audit)
moins de 24 heures	évaluer : données et personnes concernées, établissements touchés, risque pour les personnes ; **informer les établissements concernés** (Nhill Solution est leur sous-traitant, document 06)
moins de 72 heures	**notifier l'autorité de protection des données compétente** pour les traitements dont Nhill Solution est responsable, si la violation présente un risque ; les établissements notifient pour leurs propres traitements, avec l'aide de Nhill Solution

Délai (à partir de la détection)	Action
sans retard injustifié	informer les personnes concernées si le risque est élevé, en langage simple : ce qui s'est passé, conséquences, mesures prises, conseils, contact
moins de 30 jours	analyse des causes, correctifs, test, compte rendu ; mise à jour de l'audit de sécurité

4. Contenu de la notification à l'autorité

Nature de la violation ; catégories et nombre approximatif de personnes et d'enregistrements ; contact pour obtenir des informations ; conséquences probables ; mesures prises ou envisagées. Si tout n'est pas connu, notifier ce qui l'est et compléter ensuite. L'autorité compétente et son mode de saisine sont vérifiés par le conseil juridique au moment de l'incident (H-05).

5. Registre des incidents

Chaque incident, même non notifié, est consigné avec les colonnes suivantes :

Date de détection	Description	Données et personnes	Risque	Mesures	Notification à l'autorité (date)	Information des personnes (date)	Clôture

6. Exercice

Simuler un incident une fois par an (par exemple : perte d'une sauvegarde) et mesurer les délais réels.